UNIVERSIDAD PERUANA UNIÓN
Facultad de Ingeniería y Arquitectura · Escuela Profesional de Ingeniería de Sistemas

Guía Práctica — Sesión 11: Seguridad Frontend SPA

Implementación de Login, Sesión con Expiración, Interceptores HTTP, Guards, Menú por Permisos y Manejo de 401/403 en PharmaSoft

Unidad: II. Frontend SPA empresarial seguro	**Sesión:** 11 (22 de octubre de 2026)
Estudiante: Sebastián Gamarra	**Docente:** Reyna Barreto Benjamin David
Ciclo / Modalidad: IV Semestre 2026-2 · Individual laboratorio	**Tecnologías:** Angular 22 · TypeScript · Spring Boot 4 (JWT)
Repositorio Frontend: PharmaFrontendv1	**Rama Git:** feature/seguridad-frontend-gamarra

1. Arquitectura y Componentes Desarrollados

Para responder a los requerimientos de seguridad de la botica (PharmaSoft), se integró la SPA en Angular 22 con el backend seguro Spring Boot 4 protegiendo cada petición mediante tokens JWT, control de acceso basado en roles y permisos, y ciclo de vida de sesión persistido en sessionStorage.

Componente	Archivo y Ubicación	Función en la Seguridad
Modelos de Sesión	`core/auth/auth.model.ts`	Tipos estrictos para Permiso, LoginRequest, LoginResponse y Sesion (con timestamp expiraEn).
AuthService	`core/auth/auth-service.ts`	Única fuente de verdad en Signal reactivo, persistencia en sessionStorage y temporizador de expiración.
authInterceptor	`core/interceptors/auth-interceptor.ts`	Clona e inyecta la cabecera Authorization: Bearer <token> solo en peticiones dirigidas a la API.
errorInterceptor	`core/interceptors/error-interceptor.ts`	Atrapa respuestas HTTP 401 cerrando sesión hacia /login?expirada=1; preserva la sesión ante errores 403.
authGuard	`core/guards/auth-guard.ts`	Protege el layout principal y rutas hijas; redirige a /login recordando el returnUrl.
invitadoGuard	`core/guards/auth-guard.ts`	Impide que un usuario ya autenticado vuelva a abrir la pantalla /login, enviándolo a /inicio.
permisoGuard	`core/guards/permiso-guard.ts`	Verifica en ruta data: { permiso }; redirige a /acceso-denegado si falta la autorización.
Login	`features/auth/pages/login/`	Formulario reactivo, mensajes por campo, visibilidad de clave y protección contra Open Redirect.
Menú & Header	`layout/sidebar/ y layout/header/`	Sidebar reactivo mediante computed(); Header muestra usuario, roles, hora límite y botón salir.
***appSiPermiso**	`shared/directives/si-permiso.ts`	Directiva estructural que oculta botones de acción (Nuevo, Editar, Baja) según permisos del usuario.

2. Matriz de Ejecución de las 16 Pruebas del Paso 11

Se ejecutaron ordenadamente las 16 pruebas formales exigidas en el Paso 11 de la guía de práctica, verificando el comportamiento en navegador (Chrome/Edge), consola de red F12 y sessionStorage:

N.º	Acción Ejecutada	Resultado Esperado	Resultado Obtenido	Estado	Evidencia
1	Sin sesión, escribir http://localhost:4200/ventas	Login con ?returnUrl=%2Fventas.	authGuard intercepta la ruta; redirige al login adjuntando returnUrl en queryParams.	PASA	P11-01_guard_ventas.png
2	Pulsar «Ingresar» con formulario vacío.	Mensajes en ambos campos; ninguna petición.	Formulario marca inputs como touched; muestra avisos de validación; 0 peticiones en Red.	PASA	P11-02_login_vacio.png
3	Login admin con contraseña incorrecta.	«Usuario o contraseña incorrectos» (401); sigue en login.	Backend responde 401; errorInterceptor lo excluye de logout; muestra error en el card.	PASA	P11-03_login_bad_pass.png
4	Login inactivo / Inactivo2026*	El mismo mensaje: no revela que la cuenta existe.	Mismo mensaje genérico de error de credenciales; previene enumeración de usuarios.	PASA	P11-04_login_inactivo.png
5	Login vendedor / Vendedor2026*	Vuelve a /ventas; encabezado muestra nombre, rol y expiración.	Autenticación exitosa; redirige a /ventas por returnUrl; Header muestra Lucía Ramos.	PASA	P11-05_login_ok_vendedor.png
6	Revisar en Red un GET /productos.	Lleva Authorization: Bearer eyJ…; login no lo lleva.	authInterceptor añade Bearer token eyJhbGciOi...; login sale sin cabecera.	PASA	P11-06_red_bearer.png
7	Revisar Almacenamiento de sesión.	Clave pharmasoft.sesion con token, expiraEn y permisos.	Objeto JSON presente con token, expiraEn, username, roles y permisos en sessionStorage.	PASA	P11-07_session_storage.png
8	Pulsar F5 en Productos.	Sigue con sesión en la misma página.	leerSesionGuardada() restaura la sesión desde sessionStorage sin pérdida de estado.	PASA	P11-08_f5_persistencia.png
9	VENDEDOR en Productos.	Sin «Nuevo producto» ni columna Acciones.	*appSiPermiso oculta el botón nuevo y los botones de edición/baja en cada fila.	PASA	P11-09_vendedor_productos.png
10	VENDEDOR escribe /productos/nuevo.	Página «403 · Acceso denegado» (permisoGuard).	permisoGuard intercepta la ruta por falta de CATALOGO_ESCRIBIR y carga AccesoDenegado.	PASA	P11-10_guard_403_vendedor.png
11	Con sesión, escribir /login.	Redirige a /inicio (invitadoGuard).	invitadoGuard detecta autenticado() === true y redirige inmediatamente a /inicio.	PASA	P11-11_invitado_guard.png
12	«Cerrar sesión»	Login; pharmasoft.sesion ya no existe.	clearTimeout, eliminación de sessionStorage, reset de signal y redirección a /login.	PASA	P11-12_logout_limpieza.png
13	Login almacen; escribir /ventas.	Ventas no está en menú y URL directa muestra «Acceso denegado».	Sidebar filtra la opción Ventas; acceso manual por URL es bloqueado por permisoGuard.	PASA	P11-13_almacen_ventas_403.png
14	Login supervisor	Ve Ventas y también botones de edición del catálogo.	Unión de permisos (VENDEDOR + ALMACENERO); menú completo y acciones activas.	PASA	P11-14_supervisor_union.png
15	En sessionStorage cambiar un carácter del token y pulsar F5.	Backend responde 401; SPA vuelve al login con «Su sesión expiró».	Al realizar GET /productos, firma JWT falla (401); errorInterceptor expulsa a /login?expirada=1.	PASA	P11-15_token_alterado_401.png
16	Backend app.jwt.expiracion-minutos: 1; entrar y esperar.	Al minuto, SPA vuelve a login con «Su sesión expiró»; reingresa a misma página.	Temporizador de AuthService dispara cerrarSesion('expirada', url) de forma precisa.	PASA	P11-16_expiracion_1min.png

3. Lista de Cotejo de Evaluación y Registro Git

N.º	Criterio Observable	Cumplimiento	Observación Técnica
1	El login valida el formulario, muestra el 401 del backend y no revela qué dato falló.	SÍ	Validadores requeridos, longitud máxima y mensaje unificado.
2	AuthService guarda la sesión en un signal y en sessionStorage, con el instante de vencimiento.	SÍ	Signal reactivo y persistencia bajo clave pharmasoft.sesion.
3	La sesión sobrevive a un F5 y se descarta si venció; un temporizador la cierra al vencer.	SÍ	leerSesionGuardada() y setTimeout programado dinámicamente.
4	authInterceptor agrega Authorization: Bearer solo a las peticiones dirigidas a la API.	SÍ	Filtra con req.url.startsWith(environment.apiUrl).
5	errorInterceptor cierra la sesión ante un 401 (salvo en el login) y no ante un 403.	SÍ	Excluye /auth/login; preserva sesión en 403 para feedback.
6	authGuard protege el layout y recuerda returnUrl; invitadoGuard protege el login.	SÍ	canActivate y canActivateChild en rutas privadas.
7	permisoGuard usa el permiso declarado en data y lleva a «Acceso denegado».	SÍ	Lee route.data['permiso'] y navega a /acceso-denegado.
8	El login solo redirige a rutas internas (sin redirección abierta).	SÍ	Validación estricta url.startsWith('/') && !url.startsWith('//').
9	El menú y los botones se muestran según los permisos (computed y *appSiPermiso).	SÍ	Directiva estructural reactiva con Effect y ViewContainerRef.
10	El encabezado muestra el usuario, sus roles y la expiración, y permite cerrar sesión.	SÍ	Template adaptado con DatePipe y evento click a cerrarSesion().
11	La rama tiene al menos cuatro commits según la convención y PR hacia develop.	SÍ	4 commits atómicos convencionales publicados en GitHub.

Registro de Commits Git (Paso 12 — Rama feature/seguridad-frontend-gamarra):

- 688ddaa: feat(auth): AuthService con sesión en sessionStorage y expiración
- e5adea1: feat(auth): interceptores de token y de errores 401
- 8a19589: feat(auth): login, guards y rutas protegidas
- 6cd39de: feat(auth): menú y acciones según permisos